

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: CRYPTOGRAPHY AND NETWORK SECURITY
COURSE CODE: CSA51

COURSE OUTCOME COVERED

CO2: Analyze Public Key crypto system strategies using RSA and key Exchange for Encryption algorithm to strengthen information security. (BL4,BL5)

Scenario-Based : 20%

QUESTIONS: Total Marks: 50 Annexure A

Code of Conduct:

I T Sanhith(192311228) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Annexure A Scenario-based

1. Secure Data Transmission using Block Cipher

A company is transmitting repeated financial data blocks over a network. Initially, they used ECB mode and noticed patterns in ciphertext.

A. Explain why this issue occurs.

B. Suggest a more secure block cipher mode and justify your choice based on the scenario.

ANS:

Secure Data Transmission using Block Cipher

A company is transmitting repeated financial data blocks over a network. Initially, they used ECB mode and noticed patterns in ciphertext.

A. Explain why this issue occurs.

ECB (Electronic Code Book) mode encrypts every block of plaintext independently using the same key, without linking one block to another. As a result, whenever the same plaintext block appears more than once (which is common in financial data such as repeated amounts, account numbers, or fixed headers), it always produces the exact same ciphertext block. This creates a visible, repeating pattern in the ciphertext. An attacker who observes this pattern can infer relationships between the underlying plaintext blocks, deduce structural information, or even carry out block replay and rearrangement attacks, even without breaking the encryption key itself.

B. Suggest a more secure block cipher mode and justify your choice based on the scenario.

A more secure choice would be CBC (Cipher Block Chaining) mode, or preferably GCM (Galois/Counter Mode) for this scenario.

- **CBC Mode:** Each plaintext block is XORed with the previous ciphertext block before encryption, and a random Initialization Vector (IV) is used for the first block. This ensures that even identical plaintext blocks produce completely different ciphertext blocks, eliminating the pattern leakage seen in ECB.
- **GCM Mode:** In addition to hiding patterns like CBC, GCM also provides authenticated encryption, generating an authentication tag that verifies both the confidentiality and integrity of the data. Since financial transactions must not only be kept secret but also be protected from tampering, GCM is the strongest and most justified choice for a banking/financial data transmission scenario.

2. Choosing an Encryption Algorithm for Banking System

- **A banking application needs high security and moderate performance for encrypting customer transactions. The available options are DES, 3-DES, and Blowfish.**
- **A. Identify the most suitable algorithm for this scenario.**
- **B. Justify your choice based on security strength and efficiency.**

ANS:

Choosing an Encryption Algorithm for Banking System

A banking application needs high security and moderate performance for encrypting customer transactions. The available options are DES, 3-DES, and Blowfish.

A. Identify the most suitable algorithm for this scenario.

Among the three given options, 3-DES (Triple DES) is the most suitable algorithm for this banking scenario.

B. Justify your choice based on security strength and efficiency.

- DES uses only a 56-bit key, which is now considered insecure since it can be brute-forced with modern computing power in a relatively short time. It is unsuitable for a banking system that requires high security.
- 3-DES applies the DES algorithm three times in succession using two or three independent keys, effectively extending the key length to 112 or 168 bits. This makes brute-force attacks computationally infeasible, providing a strong and well-tested level of security. It has also historically been widely accepted and certified (e.g., under FIPS and PCI-DSS) for use in financial and banking environments, which adds a compliance advantage.
- Blowfish is faster and free to use, with a flexible key length up to 448 bits, but it operates on a 64-bit block size. When encrypting very large volumes of data, as banking systems typically do, a 64-bit block size becomes vulnerable to birthday-bound (collision) attacks, making it less suitable despite its speed.
- Overall, since the requirement is high security with only moderate performance, 3-DES offers the best balance: its slower speed compared to Blowfish is an acceptable trade-off for the stronger, more trusted security guarantee needed in banking.

3. Key Exchange in an Unsecured Network

Two users want to establish a secure communication channel over a public network using Diffie-Hellman key exchange. However, the network is vulnerable to attacks.

- A. Explain how the key exchange works in this scenario.
- B. Identify a possible security threat and suggest a solution to mitigate it.

ANS:

Key Exchange in an Unsecured Network

Two users want to establish a secure communication channel over a public network using Diffie-Hellman key exchange. However, the network is vulnerable to attacks.

A. Explain how the key exchange works in this scenario.

In Diffie-Hellman (DH) key exchange, both users first agree publicly on a large prime number (p) and a generator/base value (g). Each user then privately selects a secret random number: User A chooses a private value ' a ' and User B chooses a private value ' b '.

- User A computes the public value $A = g^a \bmod p$ and sends A to User B.
- User B computes the public value $B = g^b \bmod p$ and sends B to User A.
- User A then computes the shared secret key as $K = B^a \bmod p$.
- User B computes the same shared secret key as $K = A^b \bmod p$.

Mathematically, both calculations yield the same value $K = g^{(ab)} \bmod p$, so both users arrive at an identical shared secret key without ever transmitting the key itself over the network. This shared key can then be used for symmetric encryption of subsequent communication.

B. Identify a possible security threat and suggest a solution to mitigate it.

Threat: Since plain Diffie-Hellman does not authenticate the identity of the two parties, it is vulnerable to a Man-in-the-Middle (MITM) attack. An attacker positioned between User A and User B can intercept both public values and substitute them with the attacker's own public values, establishing two separate shared keys, one with each user, while relaying and decrypting all traffic without either user's knowledge.

Solution: The key exchange should be authenticated, for example by digitally signing the exchanged public values using RSA or DSA signatures, or by using certificates issued by a trusted Certificate Authority (CA) as part of a Public Key Infrastructure (PKI). Protocols such as the Station-to-Station (STS) protocol, or using DH within TLS with certificate-based authentication, ensure that each party can verify the other's identity before trusting the exchanged keys, effectively preventing MITM attacks.

4. Public Key Cryptography for Email Security

An organization plans to implement RSA for secure email communication.

A. Describe how RSA can be used for encryption and decryption in this scenario.

B. Explain how key distribution and management play a role in maintaining security.

ANS:

Public Key Cryptography for Email Security

An organization plans to implement RSA for secure email communication.

A. Describe how RSA can be used for encryption and decryption in this scenario.

In RSA, each user generates a mathematically linked key pair: a public key, which can be shared with anyone, and a private key, which is kept secret.

- Encryption: When Sender wants to send a confidential email to Receiver, Sender encrypts the message using Receiver's public key.
- Decryption: Only Receiver's corresponding private key can decrypt the message, ensuring that even if the email is intercepted, no one else can read its contents.
- Authentication/Integrity: For sender verification, the sender can compute a hash of the message and encrypt (sign) it with their own private key. The receiver decrypts this signature with the sender's public key to confirm the message truly came from the claimed sender and was not altered.
- In practice, because RSA is computationally slow for large data, a hybrid approach is used: RSA encrypts a randomly generated symmetric session key, and the actual email content is encrypted using a fast symmetric algorithm (such as AES) with that session key.

B. Explain how key distribution and management play a role in maintaining security.

The strength of RSA depends entirely on the trustworthy distribution and management of keys, not just the algorithm itself.

- Key Distribution: Public keys must be reliably bound to the correct identity so that a sender is certain they are encrypting with the genuine recipient's key, and not an attacker's substituted key. This is typically achieved through digital certificates issued by a trusted Certificate Authority (CA) within a Public Key Infrastructure (PKI).
- Key Management: Private keys must be generated securely, stored safely (e.g., in hardware security modules or encrypted key stores), and never shared. Organizations

must also implement key rotation/renewal policies, and a revocation mechanism (such as a Certificate Revocation List or OCSP) to immediately invalidate a key if it is lost, stolen, or compromised.

- Without proper key distribution and lifecycle management, even a mathematically strong algorithm like RSA can be undermined, for example through impersonation, key compromise, or use of expired/revoked keys.

5. Cryptography for IoT Devices

- **A smart home system uses low-power IoT devices that need secure communication. The designer must choose between RSA and Elliptic Curve Cryptography (ECC).**
- **A. Analyze the constraints of IoT devices.**
- **B. Recommend a suitable cryptographic approach and justify your answer**

ANS:

Cryptography for IoT Devices

A smart home system uses low-power IoT devices that need secure communication. The designer must choose between RSA and Elliptic Curve Cryptography (ECC).

A. Analyze the constraints of IoT devices.

- Limited processing power: IoT devices typically use small, low-power microcontrollers that cannot efficiently perform computationally heavy operations.
- Limited memory and storage: Devices often have only a few kilobytes of RAM/flash memory, restricting the size of keys, certificates, and cryptographic code that can be stored and executed.
- Limited battery/energy: Many IoT devices run on batteries and must conserve power, so energy-intensive cryptographic computations shorten device lifespan.
- Low bandwidth and network constraints: IoT networks often have limited bandwidth, so large keys or certificates increase transmission overhead and latency.
- Scalability: A smart home or IoT deployment may involve many devices, so the cryptographic approach must scale efficiently across a large number of endpoints.

B. Recommend a suitable cryptographic approach and justify your answer.

Elliptic Curve Cryptography (ECC) is the more suitable approach for this IoT scenario.

- Smaller key sizes for equivalent security: ECC achieves the same security strength as RSA with a much smaller key size, for example a 256-bit ECC key offers security

comparable to a 3072-bit RSA key. This drastically reduces the amount of data that needs to be stored, processed, and transmitted.

- Lower computational and power requirements: Because of the smaller key sizes, ECC operations require significantly less processing power and energy than RSA, making it far more suitable for battery-powered, resource-constrained IoT devices.
- Reduced bandwidth usage: Smaller keys and certificates mean less data sent over the network, which is beneficial given the low-bandwidth nature of many IoT networks.
- Conclusion: Given the strict constraints on processing power, memory, energy, and bandwidth in IoT devices, ECC provides an equivalent level of security to RSA while being far more lightweight and efficient, making it the recommended cryptographic approach for the smart home system.